



DOCUMENTO DE ARQUITETURA DE SOFTWARE

Plataforma Digital SST — Consultoria em Segurança do Trabalho

SAD v1.0 | Blueprint Técnico & Roadmap de Produto

Versão	1.0 — Inicial
Data	2025
Classificação	Confidencial — Uso Interno
Escopo	Plataforma Web + Portal + CRM + IA
Horizonte	MVP (4 sem.) + Escala (10 anos)

"O site que vende enquanto você dorme."

1. Sumário Executivo

Este documento descreve a arquitetura completa da Plataforma Digital SST — uma solução web de alta conversão para consultorias de Segurança do Trabalho. O objetivo não é entregar apenas um site institucional, mas sim construir uma máquina de geração de receita, autoridade de mercado e retenção de clientes, operando 24/7 com custo marginal próximo de zero.

1.1. Problema Central

O mercado brasileiro de SST é composto majoritariamente por profissionais autônomos e pequenas consultorias com presença digital nula ou inadequada. Os sintomas são sistêmicos:

- 97% dos visitantes saem em menos de 10 segundos por falta de proposta de valor clara
- Taxa de conversão média de 0,5% contra benchmark de 3–5% para serviços B2B
- Zero rastreabilidade de leads — o TST não sabe quantas oportunidades perdeu
- SEO inexistente — invisível para buscas no Google por palavras-chave de alta intenção
- Sites quebrados em mobile, onde 65% do tráfego B2B já ocorre

1.2. Solução Proposta

Uma plataforma em três camadas funcionais — Aquisição, Conversão e Retenção — construída sobre stack moderna (Next.js + Supabase), com SEO estrutural desde o dia 1, calculadoras interativas como diferencial de engajamento, automações de WhatsApp/email para follow-up imediato e um portal do cliente que transforma serviços pontuais em receita recorrente.

1.3. Resultado Esperado

Métrica	Situação Atual	Meta 6 Meses	Meta 12 Meses
Taxa de Conversão	0,5%	3%	5%
Visitantes Únicos/Mês	< 100	3.000	10.000
Posição Google (SST + cidade)	Não indexado	Top 5	Top 1
Leads/Mês	0–2	90–150	400–500
Receita Recorrente (MRR)	R\$ 0	R\$ 8.000	R\$ 30.000

2. Análise Crítica do Blueprint Original

2.1. O que está correto e deve ser preservado

- Foco em conversão como função primária — correto e raro no segmento
- Calculadora de multas como lead magnet interativo — diferencial real de engajamento
- SEO estrutural com páginas de serviço individuais — fundação sólida
- Formulário multi-etapa para qualificação de lead — reduz atrito e aumenta qualidade
- Stack Next.js + Supabase — escolha adequada para o contexto
- Estratégia de blog com calendário editorial — abordagem correta para SEO de médio prazo

2.2. Over-Engineering no MVP — O que Eliminar

O blueprint original contém componentes válidos para escala mas que criam overhead desnecessário na fase MVP:

Componente	Status MVP	Justificativa
Portal do Cliente (v1)	Adiar para Mês 3	Sem clientes recorrentes, não há valor. Custo alto, ROI zero no MVP.
Chatbot com IA (Claude API)	Adiar para Mês 4	Chatbot por regras fixas responde 90% das dúvidas. IA adiciona R\$ 600/ano sem conversão proporcional.
Email Drip Campaign (Loops.so)	Adiar para Mês 2	Sem lista de email, ferramenta ociosa. Prioridade: gerar leads primeiro.
tRPC (type-safety API)	Substituir por API Routes simples	Over-engineering. Time to market maior sem benefício real em volume < 10k req/dia.
12 páginas de serviço no Dia 1	Iniciar com 4–6 páginas	Conteúdo raso em 12 páginas é pior para SEO que conteúdo profundo em 6.

2.3. Riscos Críticos Não Endereçados no Blueprint

⚠ RISCO ALTO — Ausência de Estratégia LGPD

O blueprint original não menciona LGPD em nenhum momento. Calculadora, formulários e chatbot coletam dados pessoais (email, CNPJ, telefone, número de funcionários). Sem base legal documentada, a consultoria está exposta a multas de até 2% do faturamento ou R\$ 50 milhões (art. 52, LGPD). Ver Seção 5 para arquitetura de conformidade.

⚠ RISCO MÉDIO — Dependência de Serviços Externos sem Fallback

Twilio (WhatsApp) e Resend (email) são pontos únicos de falha no fluxo crítico de confirmação de leads. Downtime de 2h em um desses serviços = leads perdidos sem recovery. Arquitetura deve incluir filas de mensagens com retry.

⚠ RISCO MÉDIO — SEO Local sem Estratégia de Reviews

Google Meu Negócio foi mencionado mas sem processo sistematizado de coleta de reviews. Para SST local, empresas com 20+ reviews 5 estrelas superam concorrentes com DA maior. Isso é ação humana, não técnica — precisa de processo operacional.

✓ CORREÇÃO — Plausible vs PostHog

Blueprint menciona ambos. Para MVP, usar apenas Plausible Cloud (R\$ 45/mês). PostHog self-hosted adiciona complexidade operacional sem benefício real até 50k eventos/mês. Migrar para PostHog Cloud apenas quando precisar de funnels avançados.

3. Arquitetura Técnica Detalhada

3.1. Visão de Sistema — Diagrama em Texto

CAMADA DE APRESENTAÇÃO (Browser / CDN)

[Next.js 15 App Router] – SSG/ISR para home e serviços | SSR para portal | CSR para formulários

[Cloudflare CDN] – Edge cache, DDoS, HTTPS/2

CAMADA DE API (Next.js API Routes)

/api/lead – Recebe form → valida → salva → dispara email/WhatsApp

/api/calculator – Calcula multa (sem DB, lógica pura)

/api/chatbot – Rules engine → fallback AI → fallback WhatsApp

/api/portal – CRUD documentos/treinamentos (auth required)

CAMADA DE DADOS

[Supabase Postgres] Leads | Clients | Documents | Trainings | Events

[Supabase Storage] PDFs, certificados, logos

[Supabase Auth] Portal do cliente (RLS por company_id)

SERVIÇOS EXTERNOS

Resend (email) → Twilio/Evolution (WhatsApp) → Plausible (analytics)

Loops.so (drip) → Sanity.io (CMS fase 2) → Stripe (pagamentos fase 3)

3.2. Decisões Arquiteturais (ADRs)

ADR-001 — Estratégia de Renderização

Tipo de Página	Estratégia	Razão	Trade-off
Home, Serviços, Blog Posts	SSG + ISR 1h	LCP < 1s, custo zero CDN	Update só após 1h
Formulário de Orçamento	CSR (Client)	Estado complexo de multi-etapa	Hydration inicial
Portal do Cliente	SSR (Server)	Auth + dados sensíveis	Custo compute maior
Calculadora	CSR puro	Zero DB, lógica local	Sem SEO (correto)

ADR-002 — Autenticação e Segurança de Dados

Usar Supabase Auth com Row Level Security (RLS). Cada cliente só acessa seus próprios documentos. Implementar via policy no Postgres:

```
-- RLS Policy: clientes só veem seus documentos
CREATE POLICY client_isolation ON documents
  USING (client_id = (SELECT id FROM clients
    WHERE user_id = auth.uid()));
```

ADR-003 — Filas de Mensagens (Correção Crítica do Blueprint)

O blueprint original fazia chamadas síncronas a Resend e Twilio dentro do handler da API. Isso cria um ponto de falha e aumenta latência do form submit para 2–4s. Correção:

- API route retorna 200 imediatamente após salvar o lead no banco
- Supabase Edge Function (trigger) processa email/WhatsApp de forma assíncrona
- Retry automático com backoff exponencial em caso de falha do serviço externo
- Dead Letter Queue: leads com falha de notificação são flagados para revisão manual

ADR-004 — CMS: MDX → Sanity.io

Fase 1 (MVP, primeiros 20 posts): arquivos .mdx locais commitados no repositório. Fase 2 (PMF validado): migrar para Sanity.io com editor visual para que o TST possa criar conteúdo sem depender de developer. O custo de migração é 1–2 dias de trabalho.

3.3. Schema de Banco — Adições Críticas

O schema original é funcional. As tabelas a seguir são adições necessárias para LGPD e analytics forense:

Tabela	Tipo	Propósito
consent_records	LGPD	Registra timestamp + IP + versão da política no momento do opt-in. Obrigatório.
data_deletion_requests	LGPD	Rastreia solicitações de exclusão (art. 18 LGPD). SLA de 15 dias úteis.
audit_log	Segurança	Log imutável de acesso a dados sensíveis no portal. Detecta vazamentos.
notification_queue	Operacional	Fila de mensagens WhatsApp/email com status (pending/sent/failed) e retry count.
ab_experiments	Analytics	Rastreia variantes de A/B tests (headlines, CTAs) por session_id.

4. Segurança e Conformidade LGPD

4.1. Mapeamento de Dados Pessoais (ROPA)

A Lei Geral de Proteção de Dados (Lei 13.709/2018) exige que o controlador (a consultoria SST) documente todos os dados pessoais coletados. O mapeamento abaixo é o ponto de partida do processo de conformidade:

Dado Coletado	Onde Coletado	Base Legal (LGPD)	Finalidade	Retenção
Email	Calc. / Form / Checklist	Legítimo Interesse / Contrato	Envio de orçamento, drip	5 anos ou exclusão por solicitação
WhatsApp / Telefone	Formulário Orçamento	Execução de Contrato	Confirmação e atendimento	Duração do contrato + 5 anos
CNPJ / Razão Social	Formulário Orçamento	Execução de Contrato	Emissão de documentos SST	Obrigaçao legal (10 anos CLT)
IP / Navegação	Plausible Analytics	Legítimo Interesse	Análise de tráfego	90 dias (Plausible padrão)
Dados de Funcionários	Portal do Cliente	Execução de Contrato	Emissão de certificados NR	Validade do certificado + 5 anos

4.2. Arquitetura de Consentimento

O consentimento deve ser inequívoco, granular e revogável. A implementação técnica obrigatória:

- Banner de cookies NÃO é necessário para Plausible (analytics sem cookies de rastreamento individual). Isso elimina pop-up chato e mantém conformidade.
- Checkbox obrigatório (não pré-marcado) no formulário de orçamento e calculadora com link para Política de Privacidade
- Registro de consentimento na tabela consent_records com: IP hash (não o IP completo), timestamp UTC, versão da política, texto exato exibido
- Link de cancelamento de email marketing em todos os emails automáticos (CAN-SPAM / art. 18 LGPD)
- Página /privacidade com política completa, atualizada, sem juridiquês desnecessário

4.3. Segurança de Aplicação

Ameaça	Criticidade	Mitigação
CNPJ/CPF Harvesting via calculadora	ALTA	Rate limiting: max 10 cálculos/IP/hora. Cloudflare WAF. CAPTCHA se > 5 req/min.

Ameaça	Criticidade	Mitigação
Spam em formulários (bots)	ALTA	Honeypot field invisível + hCaptcha (privacy-first, LGPD-ok) + validação server-side Zod.
Enumeração de leads via API	ALTA	API routes sem autenticação retornam sempre 200 (mesmo em erro) para não vazarem informações.
Acesso indevido ao portal	ALTA	Supabase Auth + RLS + MFA opcional. Sessão expira em 8h. Log de acesso em audit_log.
XSS em inputs de formulário	MÉDIA	Sanitização via Zod + DOMPurify no display. Next.js escapa JSX por padrão.
SQL Injection	BAIXA	Supabase client usa queries parametrizadas por padrão. Nunca concatenar SQL.
Exposição de env vars / API keys	CRÍTICA	Keys sensíveis NUNCA no frontend. Usar NEXT_PUBLIC_ apenas para IDs públicos. Vercel Env Vars para secrets.

4.4. Headers de Segurança HTTP (next.config.js obrigatório)

```
// next.config.js — Headers de segurança obrigatórios
headers: [
  { key: 'X-Frame-Options', value: 'DENY' },
  { key: 'X-Content-Type-Options', value: 'nosniff' },
  { key: 'Referrer-Policy', value: 'strict-origin-when-cross-origin' },
  { key: 'Permissions-Policy', value: 'camera=(), microphone=()' },
  { key: 'Strict-Transport-Security', value: 'max-age=63072000' },
  { key: 'Content-Security-Policy', value: "default-src 'self'" }
```


5. Priorização MVP — O que Construir Primeiro

5.1. Framework de Priorização

Cada feature foi avaliada pelo índice de impacto no revenue ÷ esforço de implementação. Features com score > 8 entram no MVP. Features com score < 5 são adiadas.

Feature	Impacto Revenue	Impacto SEO	Impacto UX	Esforço (1-10)	Score	Sprint
Hero Section com CTA duplo	10	8	10	2	14	Semana 2
Formulário de orçamento (4 etapas)	10	3	8	4	12	Semana 3
Calculadora de multas	9	6	10	3	12	Semana 3
4 páginas de serviço SEO (PGR, NR35, NR33, APR)	8	10	7	4	11	Semana 2–3
Integração email (Resend) + WhatsApp (Twilio)	9	0	7	3	11	Semana 3
3 posts de blog SEO	4	10	5	5	9	Semana 4
Google Meu Negócio + Schema markup	7	10	3	1	13	Semana 4
Chatbot regras fixas (sem IA)	5	0	6	3	8	Mês 2
Portal do Cliente	8	0	9	8	6	Mês 3
Chatbot IA (Claude API)	4	0	7	5	5	Mês 4

5.2. Cronograma MVP Revisado (4 Semanas)

Período	Entregáveis	Critério de Aceite
Semana 1	Domínio + Vercel + Supabase + Next.js boilerplate + identidade visual + wireframes Figma	Deploy ativo em https://dominio.com.br, DB conectado, CI/CD funcionando
Semana 2	Home completa (hero, depoimentos, CTAs) + 4 páginas de serviço + Sobre + SEO básico	PageSpeed Insights > 85 mobile. Title/meta em todas as páginas. Schema markup validado.
Semana 3	Calculadora de multas + Formulário 4 etapas + Integração Resend + Twilio + LGPD consent + Analytics Plausible	Lead de teste chegando no email do TST em < 30s. Consentimento gravado no DB. Calculadora funcionando offline.

Período	Entregáveis	Critério de Aceite
Semana 4	3 posts de blog + Google Meu Negócio + Checklist PDF gratuito + Testes cross-browser + Launch	Google Search Console indexando. GMN verificado. 0 erros de formulário em 50 submissões de teste.

6. Visão de 10 Anos — Limites de Escala e Evolução

A maior parte das decisões técnicas tomadas no MVP será irrelevante daqui a 5 anos. O que importa é não construir paredes que impeçam a evolução. Esta seção mapeia os limites previsíveis e as rotas de fuga.

6.1. Mapa de Crescimento por Horizonte

Horizonte	Foco Estratégico	Funcionalidades Chave	Limite Técnico a Endereçar
Ano 1	Product-Market Fit	Site + SEO + Leads + Portal básico	Schema DB simples, monolito Next.js é suficiente
Ano 2–3	Escala Regional	Multi-tenancy (várias cidades), marketplace de TSTs, pagamento online, app mobile PWA	Supabase Free tier estoura. Migrar para Supabase Pro. Avaliar separação de domínios (monorepo).
Ano 3–5	Plataforma Vertical	SaaS para TSTs (white-label), módulo de gestão de EPI, integração com eSocial, assinatura digital ICP-Brasil	Next.js monolito começa a sobrecarregar. Separar portal em serviço independente. BFF pattern.
Ano 5–10	Ecossistema SST	Marketplace de documentos, IA generativa para geração de PGR, integração MTE, certificação digital automática	Necessidade de microserviços reais. Separar: auth, documents, notifications, AI. Eventual consistency.

6.2. Limites de Escala Previsíveis

Limite 1 — Supabase Free Tier (Ano 1–2)

Gatilho de Migração

500MB de banco de dados (atinge com ~50.000 documentos PDF armazenados)

2GB de transferência/mês (atinge com ~10.000 visitantes únicos/mês com assets grandes)

Ação: Upgrade para Supabase Pro (R\$ 125/mês) — sem mudança de código, apenas billing.

Limite 2 — Next.js Monolito como SaaS Multi-Tenant (Ano 2–3)

Quando o produto evoluir para atender múltiplos TSTs (não apenas um), a arquitetura atual de tenant único vai criar problemas de isolamento de dados e customização de marca. Rota de fuga:

- Implementar subdomain routing no Next.js middleware (tst-joao.seudominio.com.br)
- Adicionar company_id em todas as tabelas existentes — migração de 2h com Supabase Migrations
- RLS policies por company_id — já preparadas na estrutura atual

- Custo incremental: zero — a arquitetura Supabase suporta isso nativamente

Limite 3 — Geração de Documentos SST com IA (Ano 3–5)

O diferencial competitivo de longo prazo não é o site — é a capacidade de gerar automaticamente PGRs, APRs e OSs a partir de dados coletados no formulário. Isso requer:

- LLM fine-tuned em normas NR (custo: R\$ 15.000–50.000 em treinamento, viável em escala)
- Validação jurídica humana obrigatória — IA como rascunho, TST como assinante
- Integração ICP-Brasil para assinatura digital com validade legal
- Armazenamento em blockchain privada para imutabilidade de versões (opcional, premium)

Limite 4 — Integração eSocial / e-CAT (Ano 2–3)

Oportunidade Estratégica

O eSocial exige que as empresas reportem riscos ocupacionais, acidentes e treinamentos em tempo real. A plataforma pode se tornar o middleware entre o TST e o governo: preenche o portal do cliente → sistema exporta XML para eSocial automaticamente. Isso cria lock-in quase impossível de quebrar.

Stack necessária: XML generation (Libxml2 via Node), certificado A1/A3 do cliente, integração com API REST do eSocial.

6.3. Moat Competitivo — O que é Difícil de Copiar

Sites são copiáveis em 48h. O moat real desta plataforma está em camadas que levam tempo para acumular:

Ativo Estratégico	Tempo para Construir	Por que é Difícil de Copiar
Autoridade SEO (backlinks + reviews)	6–18 meses	Domain Authority acumulado, posição #1 no Google local — concorrente precisaria do mesmo tempo para superar.
Base de Clientes com Histórico	12–24 meses	Alertas automáticos de vencimento criam dependência. Cliente não troca porque perderia histórico de treinamentos.
Dados de Comportamento de Lead	6–12 meses	Após 1.000 leads, o modelo de scoring sabe quais combinações (setor + tamanho + urgência) fecham mais. Concorrente parte do zero.
Conteúdo de Blog Indexado	6–12 meses	30+ artigos bem ranqueados = tráfego gratuito orgânico. Requer tempo, não apenas dinheiro.
Integração eSocial (fase 2)	18–36 meses	Complexidade técnica + certificação digital + validação jurídica = barreira de entrada altíssima.

7. Arquitetura de Conversão — Onde o Visitante Trava

7.1. Mapa de Atrito por Etapa do Funil

Cada ponto de decisão no funil tem objeções previsíveis. Ignorá-las é o principal motivo de baixa conversão em sites de consultoria.

Etapa do Funil	Objeção Real do Visitante	Gatilho de Abandono	Solução Técnica
Chegada na Home	"Mais um site igual. Por que eu deveria confiar?"	Headline genérica, sem prova social acima do fold	Headline focada na DOR (multa), trust badges visíveis, depoimento com nome + empresa real
Considerando serviços	"Quanto custa? Não quero revelar interesse antes de saber o preço."	Preço escondido, formulário antes de qualquer informação de valor	Preço âncora "a partir de" visível nos cards. Calculadora como primeiro passo (baixa barreira).
Iniciando formulário	"Formulário longo demais. Vou preencher depois."	Formulário de uma página com 10+ campos	Multi-etapa: 4 telas com 2–3 campos cada. Barra de progresso. Primeiro campo = apenas nome da empresa.
Após envio	"Ninguém vai responder. Já preenchi formulário de concorrente e sumiu."	Página genérica de 'obrigado' sem comprometimento de prazo	Confirmação: "Resposta em até 2 horas" + WhatsApp automático imediato com nome do TST.
Pós-proposta	"Vou pensar." (= perdido sem follow-up)	Zero automação pós-proposta	Sequência de 3 emails automáticos: D+1 (urgência), D+3 (caso de sucesso), D+7 (oferta final).

7.2. Copywriting de Alta Conversão — Princípios

A diferença entre 0,5% e 5% de conversão raramente é técnica. É copy. Princípios obrigatórios:

- DOR antes de solução: "Sua empresa pode ser multada em R\$ 87.000" converte mais que "Oferecemos PGR completo"
- Especificidade > generalidade: "Entrega em 48h" bate "entrega rápida" por fator 3x em CTR
- Social proof com números reais: "127 empresas atendidas" > "Muitos clientes satisfeitos"
- Urgência real, não artificial: Mudanças recentes em NRs são urgência legítima. Usar com responsabilidade.

- Objeção antecipada: Seção de FAQ com as 5 perguntas que impedem a compra. Responder antes de ser perguntado.

8. Dashboard de Métricas e KPIs

8.1. Métricas Primárias (Decisão Semanal)

KPI	Benchmark Mercado	Meta Mês 1	Meta Mês 6	Fonte
Taxa de Conversão Visitante → Lead	0,5–1%	2%	5%	Plausible + DB
Bounce Rate	70–80%	< 60%	< 45%	Plausible
Tempo Médio no Site	< 1 min	> 1,5 min	> 3 min	Plausible
% Visitantes que Usam Calculadora	N/A	> 10%	> 20%	Evento Custom Plausible
Tempo de Resposta ao Lead (TST)	24–72h	< 2h	< 30 min	CRM (status campo)
Taxa Lead → Cliente	5–10%	10%	20%	Supabase
Posição Google ("SST + cidade")	Não ranqueado	Top 20	Top 3	Google Search Console
Core Web Vitals — LCP	< 2,5s (bom)	< 1,5s	< 1s	PageSpeed Insights

8.2. Eventos de Analytics a Trackear (Dia 1)

Plausible suporta eventos customizados sem cookies. Estes são obrigatórios desde o primeiro deploy:

- `calculated_fine` — disparado quando o usuário executa a calculadora (com valor calculado como propriedade)
- `form_started` — quando o usuário clica no primeiro campo do formulário de orçamento
- `form_step_N_completed` — por etapa concluída (mede onde há abandono no multi-step)
- `form_submitted` — envio bem-sucedido do formulário
- `checklist_downloaded` — download do PDF gratuito
- `whatsapp_clicked` — clique em qualquer botão WhatsApp (mede intenção alta)
- `chatbot_opened` / `chatbot_converted` — abertura e conversão via chatbot

9. Custo Total de Propriedade (TCO)

9.1. Stack de Custo Zero para MVP

Serviço	Free Tier Limite	Custo Mensal	Quando Fazer Upgrade
Vercel (Hosting)	100GB bandwidth	R\$ 0	Ao ultrapassar 100GB ou precisar de Edge Functions avançadas
Supabase (DB + Auth + Storage)	500MB DB, 2GB storage	R\$ 0	Ao atingir 500MB DB (aprox. 50k documentos)
Resend (Email Transacional)	3.000 emails/mês	R\$ 0	Ao superar 3k emails (volume alto de leads)
GitHub (Repositório + CI)	Repositórios públicos ilimitados	R\$ 0	Repositório privado: GitHub Free inclui

9.2. Custos Reais (Serviços Necessários)

Serviço	Custo/Mês	Observação
Domínio .com.br (Registro.br)	R\$ 3,30	R\$ 40/ano, pago anualmente
Plausible Analytics (cloud)	R\$ 45	Alternativa: auto-hospedado via Railway (R\$ 20/mês)
Twilio WhatsApp (aprox. 500 msgs/mês)	R\$ 50–80	Alternativa: Evolution API self-hosted (R\$ 20/mês infra + zero por mensagem)
TOTAL MÍNIMO VIÁVEL	R\$ 98–128	Domínio + Analytics + WhatsApp
TOTAL STACK COMPLETO (fase crescimento)	R\$ 270–520	+ Supabase Pro + Resend Pro + Claude API

ROI Estimado — Break-even

Com 1 cliente fechado/mês via site (média R\$ 1.200 de ticket único ou R\$ 400 MRR), o break-even do custo operacional ocorre no primeiro mês.

Com 5 clientes recorrentes (consultoria mensal), o site paga R\$ 2.000 mensais contra custo de R\$ 500. ROI de 300% sobre custos diretos.

Cada lead orgânico do Google tem CPL (custo por lead) efetivamente zero, contra R\$ 150–400 via Google Ads para o mesmo serviço.

10. Próximos Passos — Plano de Ação Executável

10.1. Checklist de Launch (Ordem Crítica)

Pré-Launch (Dias 1–3)

1. Registrar domínio em Registro.br (.com.br com nome da consultoria ou serviço principal)
2. Criar conta Vercel + conectar GitHub repository
3. Criar projeto Supabase + rodar migrations SQL do schema
4. Criar conta Resend + verificar domínio de email
5. Criar conta Twilio ou Evolution API + configurar WhatsApp Business
6. Criar conta Plausible + adicionar snippet ao next.config.js
7. Definir paleta de cores (3 cores: primária navy + secundária azul + acento) via Coolors.co

Build (Dias 4–21)

8. Implementar layout global (header, footer, nav mobile)
9. Construir Hero Section com CTA duplo e trust badges
10. Construir seção de Depoimentos (carrossel) com dados reais
11. Construir cards de Serviços (4 cards no MVP)
12. Implementar Calculadora de Multas (JS puro, sem backend)
13. Implementar formulário multi-etapa de orçamento (4 etapas)
14. Construir 4 páginas de serviço individuais (PGR, NR35, NR33, APR)
15. Implementar API route /api/lead com validação Zod + registro de consentimento
16. Integrar Resend (email para TST + confirmação para cliente)
17. Integrar Twilio (WhatsApp automático pós-formulário)
18. Implementar analytics events (Plausible custom events)
19. Escrever 3 posts de blog SEO (2.000+ palavras cada)

Launch (Dias 22–28)

20. Configurar Google Search Console + submeter sitemap.xml
21. Criar e verificar perfil no Google Meu Negócio
22. Testar formulários (50 submissões reais — verificar emails, WhatsApp, DB)
23. Executar Lighthouse audit (meta: > 85 em todas as métricas)
24. Validar schema markup via Google Rich Results Test
25. Deploy final + ativar Cloudflare (DNS, SSL, cache)
26. Anunciar lançamento em LinkedIn + grupos de RH/SST locais

10.2. Red Lines — O que Nunca Fazer

Erros Fatais a Evitar

Nunca lançar sem rastreamento de leads (sem DB ativo, você não sabe quantos clientes perdeu)
Nunca usar fotos de stock em depoimentos — destrói credibilidade instantaneamente
Nunca esconder o WhatsApp no rodapé — botão fixo flutuante é obrigatório
Nunca ter 'Saiba mais' como CTA — sempre uma ação específica ('Solicitar Orçamento', 'Calcular Multa')
Nunca lançar sem HTTPS ativo — além de inseguro, o Google penaliza no ranking
Nunca coletar dados sem consentimento registrado — risco LGPD real com multas de R\$ 50M

11. Glossário Técnico

Termo	Definição no Contexto deste Documento
SSG	Static Site Generation — páginas pré-renderizadas no build. Zero custo de servidor, máxima velocidade.
ISR	Incremental Static Regeneration — SSG que se atualiza automaticamente após N segundos sem rebuild completo.
SSR	Server-Side Rendering — página gerada no servidor a cada request. Necessário para dados dinâmicos autenticados.
RLS	Row Level Security — política no Postgres que restringe acesso a dados por usuário sem código adicional.
ROPA	Record of Processing Activities — registro obrigatório de dados pessoais coletados (LGPD/GDPR).
BFF	Backend for Frontend — serviço intermediário que adapta APIs para necessidades específicas de cada cliente.
WAF	Web Application Firewall — filtra tráfego malicioso antes de chegar ao servidor de aplicação.
LCP	Largest Contentful Paint — métrica Core Web Vitals. Tempo até o maior elemento visível ser renderizado.
MRR	Monthly Recurring Revenue — receita mensal previsível de contratos recorrentes. Principal KPI de SaaS.
CPL	Cost Per Lead — quanto custa, em média, gerar um contato qualificado (lead). Meta: R\$ 0 via orgânico.
NR	Norma Regulamentadora — regulamentos do MTE sobre saúde e segurança do trabalho. NR 1, NR 35, NR 33 são os principais.
PGR	Programa de Gerenciamento de Riscos — documento obrigatório pela NR 1 desde jan/2022. Principal serviço da consultoria.
TST	Técnico de Segurança do Trabalho — profissional registrado no MTE que elabora os documentos SST.
ADR	Architecture Decision Record — registro formal de uma decisão arquitetural, incluindo contexto e trade-offs.

12. Conclusão e Filosofia de Execução

Princípios de Execução

Simplicidade → Complexidade:

Um formulário funcional converte mais que um chatbot sofisticado que ainda não está pronto. Lance simples, itere com dados reais.

Dados → Intuição:

Nunca mude uma headline, CTA ou layout sem dados. Analytics e A/B tests decidem, não opinião. Instale o Plausible antes de escrever a primeira linha de componente.

Receita → Perfeição:

Um site que gera 1 cliente/mês hoje vale infinitamente mais que um site perfeito que lança em 3 meses. A perfeição é o inimigo do faturamento.

Fundação → Escala:

As decisões de segurança, LGPD e arquitetura de dados feitas no MVP determinam se será possível escalar sem reescrever tudo. Faça certo uma vez.

Este documento é um artefato vivo. Deve ser atualizado a cada decisão arquitetural significativa, cada mudança de roadmap e cada aprendizado extraído dos dados reais de uso. Versão 1.0 marca o início da construção — não o fim do pensamento.

FIM DO DOCUMENTO — SAD v1.0